

# ■■ Enterprise AI Security & Incident Response Standard

Document Version: 3.2.0 | Classification: CONFIDENTIAL - INTERNAL USE ONLY | Effective Date: 2026-Q1

## 1. Purpose, Scope & Governance

This document establishes the mandatory security controls, operational guardrails, and compliance standards governing all Generative AI applications, Large Language Model (LLM) agents, and Retrieval-Augmented Generation (RAG) pipelines deployed within the enterprise infrastructure.

## 2. Authentication, API Key Lifecycle & Access Control (RBAC)

- **Rule AC-101 (MFA Mandate):** Multi-Factor Authentication (MFA) is strictly required for all administrative access to AI endpoints, vector databases, and LangSmith observability dashboards.
- **Rule AC-102 (Key Rotation):** All AI API keys (OpenAI, Anthropic, LangSmith) must be rotated strictly every **30 calendar days**. Static hardcoding of API keys in source code or notebooks is a Tier-1 violation.
- **Rule AC-103 (Least Privilege):** Autonomous agents must operate under isolated service accounts with read-only vector namespace permissions scoped specifically to their assigned tenant ID.
- **Rule AC-104 (Encryption at Rest):** All credentials and model weights stored at rest must utilize AES-256-GCM encryption.

## 3. Prompt Injection, Jailbreak Defense & Input Validation

- **Rule PI-201 (Gateway Validation):** All inbound user prompts must pass through a pre-execution security gateway (e.g., Llama Guard / Guardrails AI) to detect adversarial jailbreaks and system prompt extraction attacks before model inference.
- **Rule PI-202 (Indirect Prompt Injection):** External data ingested into RAG vector databases (PDFs, web scrapes, emails) must be sanitized. Untrusted documents must never contain executable system commands or override instructions.
- **Rule PI-203 (Canary Tokens):** System prompts must embed unique cryptographic canary tokens. If a model output contains the canary token, the session must be immediately terminated and flagged as a prompt leak attempt.

## 4. Data Privacy, PII Redaction & Data Exfiltration Prevention

- **Rule DP-301 (Pre-Embedding Sanitization):** Personally Identifiable Information (PII) such as Social Security Numbers, credit cards, health records, and corporate passwords must be masked or tokenized prior to vector embedding generation.
- **Rule DP-302 (Data Residency):** Customer embeddings and query logs must remain within the designated regional cloud boundary (e.g., US-East or EU-Central). Cross-border data transfers without DPA approval are prohibited.

## 5. High-Severity Incident Response & Emergency Containment (IRP)

- **Protocol IR-401 (Isolation SLA):** In the event of a confirmed model exploit, data exfiltration breach, or autonomous agent loop runaway, the SecOps team must **isolate the model endpoint within 5 minutes**.
- **Protocol IR-402 (SOC Escalation):** Security Operations Center (SOC) must be automatically paged via PagerDuty within 15 minutes of breach detection.
- **Protocol IR-403 (Emergency Key Invalidation):** All active API tokens associated with the breached agent service must be instantly revoked through the automated identity provider webhook.

- **Protocol IR-404 (Forensic Audit):** LangSmith execution traces must be preserved for forensic analysis. A post-incident Root Cause Analysis (RCA) report must be submitted to the CISO within 48 hours.

## 6. Observability, Cost Controls & LangSmith Compliance

- **Rule OB-501 (Mandatory Tracing):** All production chains, tools, and retrievers must run with `LANGCHAIN_TRACING_V2=true` and log to the designated central LangSmith organization.
- **Rule OB-502 (Latency & Cost Thresholds):** Single-turn RAG latency must not exceed **3.5 seconds (p95)**. Maximum token cost per query is capped at **\$0.10 USD**. Automated alerts fire if costs exceed \$50/hour.
- **Rule OB-503 (Audit Log Retention):** Observability traces and execution logs must be retained for a minimum of **90 days** for SOC 2 and ISO 27001 audit compliance.